

PHASE 1 — CONSOLIDATED RESEARCH & PROBLEM VALIDATION REPORT

From Problem Discovery to a Provisional Research Problem Lock

Version 1.0 | 16 August 2026

Executive Summary

This report consolidates the major research work completed during Phase 1 of the CloudShield AI Research Lab. Its purpose is to replace the many raw Gemini outputs and intermediate reports with one authoritative working document. It preserves the important evidence, corrections, decisions, rejected assumptions, candidate research directions, and the provisional research problem that emerged from the process.

The research began with a broad hypothesis: build an AI-assisted Cloud Security Posture Management (CSPM) platform. The investigation showed that the broad CSPM concept is already highly saturated. Mature commercial CNAPP/CSPM platforms and cloud-native tools already provide asset discovery, static misconfiguration detection, risk correlation, and increasingly AI-assisted remediation. The Phase 1 evidence therefore rules out a generic 'AI-powered CSPM' as a sufficiently differentiated research contribution.

The investigation then narrowed the problem toward AI-generated Infrastructure-as-Code (IaC) remediation. Recent evidence shows a meaningful distinction between code that is syntactically valid and infrastructure that is actually secure. At the same time, existing research already combines LLMs with scanners, SAT/SMT methods, RAG, and Terraform verification. The remaining opportunity is therefore not the mere use of an LLM, Terraform, or Z3, but the specific verification of whether an AI-generated security fix improves security without breaking required infrastructure functionality.

The current provisional research direction is: a formally verified, LLM-assisted Terraform remediation framework that jointly checks security invariants and functional invariants before accepting a generated fix. The central research question compares this joint-verification approach with security-only verification and measures whether functional regressions can be reduced without imposing impractical computational overhead.

This report deliberately uses cautious language. Novelty and patentability are not claimed as established facts. They remain subject to continued prior-art monitoring and the systematic literature review in Phase 2.

1. Phase 1 Journey — What We Investigated

Module	Purpose	Outcome
1.1 Problem Landscape	Establish whether cloud posture/misconfiguration is a real and active problem.	Problem confirmed; generic CSPM already mature.
1.2 Problem Evidence	Build a quantitative evidence base.	Strong evidence collected; several statistics rejected or downgraded.

1.2A Source Verification	Check Gemini claims against primary/authoritative sources.	Important corrections made; evidence quality improved.
1.3 Stakeholder Analysis	Identify who actually experiences the problem.	SOC, DevSecOps/platform, and AI-laC users emerged as strongest candidates.
1.4 Root Cause Analysis	Understand why the problems occur.	Static/context gaps, remediation trust, insecure AI-laC, and verification gaps emerged.
1.5 Impact Analysis	Measure consequences and potential research metrics.	Security, operational, and measurable experimental impacts identified.
1.6 Existing Solution Landscape	Map commercial, academic, and open-source prior art.	Broad CSPM rejected; LLM+scanner and LLM+formal methods prior art identified.
1.7 Problem Validation	Compare candidate research directions.	AI-laC + formal methods emerged as a leading area.
1.7A–1.7F Refinement	Stress-test feasibility, prior art, and novelty.	Research problem progressively narrowed to joint security + functional verification.
1.8A–1.8C	Formalize scope, RQs, hypotheses, and problem statement.	Working research charter established.
1.9 Final Audit	Assess readiness to enter literature review.	Phase 1 provisionally approved; novelty remains monitored.

2. What Phase 1 Established

2.1 The underlying cloud-security problem is real

The evidence base consistently supports that cloud security posture, misconfiguration, identity over-permissioning, and configuration-management problems are active security concerns. The research report also identified inadequate IAM as a leading threat in recent Cloud Security Alliance material and documented large-scale industry observations on over-permissioning and remediation delays. These should be cited as industry evidence with their dataset limitations, not as universal global constants.

2.2 The broad CSPM problem is saturated

Commercial CNAPP/CSPM platforms, cloud-native services, and open-source scanners already cover core discovery and static misconfiguration detection. The consolidated solution landscape explicitly identifies static IaC scanning, agentless visibility, and rule-based compliance reporting as heavily commoditized. A research project whose main contribution is 'detect cloud misconfigurations with AI' would therefore be weakly differentiated.

2.3 AI-generated IaC introduces a distinct research problem

The research identified recent empirical benchmarks showing that an LLM can produce syntactically valid Terraform while still failing security-compliance checks. This makes secure AI-generated infrastructure a meaningful research problem. However, existing work already explores LLM+scanner and LLM+SAT feedback loops, so 'use AI to fix Terraform securely' is not sufficient novelty.

2.4 The critical tension is security versus functionality

A security remediation may remove the targeted security violation by modifying a rule, permission, or network relationship that is also required for legitimate operation. Phase 1 therefore reframed the problem as a joint-correctness question: can a generated security fix be accepted only when it satisfies both explicit security constraints and explicitly defined functional constraints?

3. Evidence Base — Key Verified Findings

Finding	Status	How We Use It
IAM is a leading cloud-security threat in current CSA survey material	Verified / Industry	Supports problem significance; label as survey evidence.
99% excessive permissions in Unit 42 analyzed dataset	Verified / Industry; year/source corrected during audit	Use only with dataset scope; not a global population statistic.
80% of alerts from 5% of rules in Unit 42 telemetry	Verified / Industry	Supports noise/triage burden; not a peer-reviewed universal rate.
60% of organizations taking >4 days to resolve security issues in Unit 42 data	Verified / Industry; source year corrected	Supports remediation delay discussion.
93% false-positive reduction in controlled AWS active behavioral experiment	Verified preliminary academic	Supports further investigation of behavioral validation; do not generalize beyond tested scenarios.
Zelkova formally reasons about AWS policy security	Verified academic/industry research	Shows formal verification of IAM is established prior art.
IAMPERE automates privilege-escalation repair using MaxSAT	Verified academic	Shows automated IAM repair is existing prior art.
LLMSecConfig combines LLM/RAG and static analysis feedback	Verified academic preprint	Shows generic LLM+SAT repair loops are prior art.
Text-to-Terraform benchmarking shows valid code can be insecure	Verified recent academic preprint	Strong evidence for secure-AI-IaC research motivation.
TerraRepair and newer verification/agent systems already use iterative IaC validation	Verified recent prior art discovery	Prevents us from claiming generic LLM+scanner/formal-loop novelty.

4. Claims We Explicitly Rejected or Downgraded

These are important because they demonstrate research discipline and should not appear as established facts in the final paper without renewed verification.

Claim	Decision	Reason
65%/68% of cloud breaches caused by misconfiguration	REJECTED	Primary source could not be reliably verified; inconsistent attribution/values were found.
100:1 machine-to-human identity ratio	DO NOT USE AS HARD STATISTIC	Insufficiently grounded dataset evidence in the reviewed material.
>70% of cloud breaches stem from compromised identities	UNVERIFIED	Exact claimed primary source was not established.
4–6 hours manual remediation / 30% new issues	SECONDARY / PREPRINT ONLY	Useful as preliminary context; underlying primary evidence requires further verification.
8x faster explainable remediation	PRELIMINARY	Synthetic/preprint evidence; not general production proof.
95% of detection techniques are static heuristics	REJECTED	Unsupported in the reviewed evidence.
“General CSPM is solved” as an absolute statement	REFINED	Better wording: core discovery/static prioritization is highly mature/commoditized.
“AI guarantees secure cloud infrastructure”	REJECTED	Formal claims must be limited to explicitly modeled invariants.

5. Stakeholder Findings

Stakeholder	Primary Pain	Research Relevance
-------------	--------------	--------------------

Security/SOC Analysts	Alert fatigue, noisy findings, manual validation	High for false-positive/context research.
DevSecOps / Platform Engineers	Remediation friction, pipeline disruption, need for safe fixes	High for security-vs-functionality research.
AI-generated IaC users	Rapid AI generation with insecure output risk	High for secure-AI-IaC benchmarking.
Cloud Security Engineers	Misconfiguration remediation, IAM, runtime drift	High, overlapping with SecOps/DevSecOps.
SME/Startup teams	Limited security talent and tool complexity	Relevant but harder to evaluate experimentally.
Cloud Architects	Architecture and identity governance	Important, but broader scope and harder to simulate.
CISOs / Security Managers	Risk, compliance, ROI	Important decision-makers; lower fit for core technical experiment.

The strongest experimentally accessible stakeholder groups were SOC/security analysts, DevSecOps/platform engineers, and teams using AI-generated IaC. Phase 1 did not force a commercial target persona; instead it selected a research problem that can be tested reproducibly by a student team.

6. Root Causes Identified

Root Cause	Mechanism	Research Relevance
Static/context-poor analysis	Rules evaluate configuration state without fully establishing runtime/exploitability context.	Motivates behavioral/context validation but is not our final focus.
Remediation trust deficit	Engineers fear a security fix can break intended behavior.	Directly motivates joint security + functional verification.
LLM security/compliance gap	LLMs can generate valid IaC that violates security policies.	Motivates verification-gated AI remediation.
Lack of deterministic feedback	LLM feedback may be textual/probabilistic rather than formally checkable.	Motivates formal constraint checking/counterexamples.
Configuration drift	Live environment can diverge from intended IaC.	Relevant context; excluded from initial prototype scope.
Identity complexity	IAM is large and difficult to reason about at scale.	Important prior art domain; not the primary experimental target initially.

7. Impact Model

Phase 1 considered security, operational, financial, time/remediation, human, reliability, compliance, and AI-automation impacts. The most research-useful impacts are those that can be measured objectively in an experiment rather than those that are only broad business claims.

Impact	How We Will Treat It
Security correctness	Primary outcome: did the vulnerability/security violation disappear?
Functional regression	Primary research outcome: did required infrastructure behavior disappear?
Successful repair rate	Percentage of generated patches satisfying both security and functional constraints.
Iterations to success	Number of LLM correction cycles required.
Verification latency	Time required by the verification layer.
Token/API cost	Useful efficiency metric if API-based models are used.
Reliability / breakage	Measured through predefined functional tests/invariants.

Business/financial impact	Contextual motivation only unless directly studied; avoid unsupported causal claims.
---------------------------	--

8. Existing Solution Landscape — What Is Already Solved

Area	Examples / Evidence	Research Decision
Static IaC scanning	Checkov, tfsec, Trivy	Do not make this the contribution.
Cloud posture / asset discovery	AWS-native tools, commercial CNAPP/CSPM	Do not build a generic CSPM.
IAM formal verification	Zelkova, IAMPERE	Treat as prior art/foundation.
LLM + scanner remediation	TerraRepair-style systems	Not novel by itself.
LLM + SAT/RAG repair	LLMSecConfig	Not novel by itself.
Formal verification + infrastructure models	Existing formal-methods work	Need narrow, cloud-specific contribution.
Functional/security evaluation of AI-generated IaC	Recent benchmark/prior-art discovered in refinement	Cannot claim that joint evaluation alone is untouched.

9. Research Candidate Evolution

Candidate	Why Considered	Why Not Final
Generic AI-CSPM	Directly addresses cloud security posture	Too saturated; insufficient research novelty.
Active Behavioral Validation	Targets false-positive/context limitations	Promising but harder testbed/scope for a 2-person team.
Explainable/Safe AI Remediation	Targets trust and safe patching	Existing research already covers substantial parts.
Secure AI-generated IaC	Strong recent evidence and easy evaluation	Basic scanner/RAG approaches already studied.
LLM + Formal Verification	Promising research intersection	Generic combination already has commercial/academic prior art.
Joint Security + Functional Verification	Strong real-world failure mode and measurable experiment	Still requires continued prior-art monitoring; final novelty must be narrowly defined.

10. Current Provisional Research Charter

Working Title

Formally Verified Security Remediation of LLM-Generated Terraform Through Joint Security and Functional Invariant Checking

Working Problem Statement

Large Language Models can accelerate Infrastructure-as-Code generation and security remediation, but a generated security fix may remove a vulnerability while unintentionally breaking required infrastructure functionality. Existing approaches can evaluate security conditions using scanners or related verification mechanisms, yet the combined problem of maintaining both security correctness and explicitly defined functional correctness during AI-assisted remediation remains a meaningful research question.

Primary Research Question

To what extent does joint formal verification of security and functional invariants reduce functional regressions in LLM-generated Terraform security remediation compared with security-only verification?

Secondary Research Questions

- 1. Does joint verification improve the proportion of successful repairs satisfying both security and functional invariants?
- 2. Does deterministic counterexample feedback reduce the number of LLM correction iterations?
- 3. What verification latency and computational cost does joint checking introduce?
- 4. Which classes of multi-resource Terraform security fixes are most likely to cause functional regressions?

Hypotheses

- 5. Joint security + functional verification will reduce functional regressions compared with security-only verification.
- 6. Formal counterexample feedback will help the LLM converge to an acceptable repair without requiring more correction iterations than the baseline by an impractical margin.
- 7. The proposed verification scope can remain computationally feasible for a constrained AWS/Terraform testbed.

11. Research Scope

Included in Initial Study	Explicitly Out of Scope
AWS	Multi-cloud
Terraform plan/state representations	Full Terraform language semantics
EC2, VPC/Subnets, Security Groups	Full AWS service catalog
Selected security invariants	Complete proof of cloud security
Selected functional/connectivity invariants	Production autonomous remediation
LLM-assisted patch generation	Kubernetes and unrelated IaC ecosystems
Deterministic formal verification	General enterprise deployment claims

12. Initial Experimental Concept

The current experimental model compares two pipelines using the same vulnerable Terraform inputs and the same LLM conditions wherever possible.

Component	Control	Treatment
Generation	LLM generates patch	LLM generates patch
Security gate	Security invariants only	Security + functional invariants
Feedback	Security failure message	Security or functional counterexample
Acceptance	Security satisfied	Security AND functionality satisfied
Primary metric	Functional regression observed after accepted patch	Functional regression observed after accepted patch

Illustrative Invariants

Security invariant examples: production EC2 must not expose SSH/RDP to 0.0.0.0/0; specified prohibited public exposure states must be absent.

Functional invariant examples: required application-to-database or application-tier connectivity must remain reachable on explicitly required ports. These are examples only; the exact invariant set must be formally specified and validated before implementation.

Practical State Representation

The current implementation hypothesis is to avoid building a full custom HCL parser. Terraform can be used to produce a plan representation, after which a Python-based bridge can map a deliberately small subset of cloud state into Z3 constraints. This is a feasibility strategy, not yet a final implementation commitment.

13. Research Integrity Rules Emerging from Phase 1

- AI-generated claims are discovery inputs, not automatically research evidence.
- Important statistics must be traced to the original source and labeled by source type.
- Industry telemetry must be distinguished from peer-reviewed academic evidence.
- No “first ever,” “guaranteed secure,” or universal superiority claims without exhaustive support.
- Formal verification claims are limited to the explicitly modeled invariants and resource semantics.
- Hypotheses must be falsifiable; target outcomes such as “0% regression” must not be assumed in advance.
- Rejected claims remain in the project history as audit evidence rather than being silently deleted.
- Novelty and patentability remain open questions and must be rechecked as the literature and prior-art search continue.

14. What Phase 1 Does NOT Yet Prove

- That the proposed approach is the first of its kind.
- That it is patentable.
- That Z3 can faithfully model every selected AWS behavior.
- That joint verification will outperform security-only verification.
- That functional invariants can be defined universally for arbitrary real-world applications.
- That the final prototype will scale to enterprise-size infrastructure.
- That a particular LLM will converge reliably within a fixed number of iterations.
- That the proposed approach is ready for production deployment.

15. Phase 1 Final Assessment

Dimension	Status	Assessment
Problem significance	Strong	Cloud security/IaC risk is supported by current academic and industry evidence.
Broad CSPM novelty	Rejected	Core CSPM detection/prioritization is too mature for the intended contribution.
Research direction	Promising	Joint security + functional verification is a clear, measurable direction.
Feasibility	Good with strict scope	A constrained AWS/Terraform prototype is realistic for a 1–2 person team.
Experimental measurability	Strong	Functional regression, repair success, iterations, latency, and cost are

		measurable.
Novelty	● Open	Requires continued monitoring and the systematic literature review.
Patentability	● Open	No patentability conclusion should be made at this stage.
Phase readiness	● Ready	The project can proceed to systematic literature review with the current problem as a provisional charter.

16. Phase 2 Starting Point

Phase 2 should not restart the entire investigation. It should systematically test and refine the provisional research problem against the academic literature. The literature review should focus on: LLM-generated IaC security; LLM-assisted remediation; formal verification of cloud/IaC; security and functional invariants; CEGAR/CEGIS and counterexample-guided synthesis; Terraform semantic modeling; AWS network/security semantics; and evaluation of AI-generated infrastructure.

The goal is to build a traceable literature matrix and determine precisely what has been done, by whom, with what datasets and methods, what limitations remain, and whether the current problem statement requires refinement before the final research gap and contribution are locked.

17. Phase 1 Source & Evidence Notes

This consolidated report was synthesized from the Phase 1 research materials generated and reviewed during the CloudShield AI Research Lab process. The raw reports remain valuable as audit/history artifacts; this document is the recommended working summary so that the project does not depend on storing every intermediate AI output as a final document.

Source Artifact	Role in Consolidation
Comprehensive CloudShield AI CSPM Research Plan	Initial broad architecture/market/competitor hypothesis and starting solution landscape.
CloudSpartanX Research Viability Analysis	Major feasibility/pivot analysis; identified saturation of generic CSPM and candidate research gaps.
Module 1.2 Evidence Report	Structured evidence matrix and statistic verification.
Module 1.4 Root Cause Analysis	Root causes and cause→effect relationships.
Module 1.5 Impact Analysis	Impact dimensions, candidate metrics, and evaluation framing.
Module 1.6 Existing Solution Landscape	Commercial/open-source/academic prior-art mapping.
Module 1.7/1.7A–1.7F Reports	Candidate selection, feasibility, prior-art refinement, and narrowing of the research direction.
Module 1.8 Research Charter	Objectives, scope, research questions, hypotheses, and working problem statement.

18. Executive Takeaway for the Research Journey

Phase 1 has achieved its primary purpose: it prevented the project from becoming a generic AI-powered CSPM. The investigation progressively rejected saturated ideas, verified important claims, exposed weak statistics, mapped existing solutions, stress-tested multiple candidate directions, and narrowed the project toward a specific experimental question. The current direction is not being presented as proven novel or patentable; it is a well-bounded provisional research charter that now deserves a systematic literature review.

In practical terms, we have moved from: 'Build an AI cloud security platform' to a much stronger research question: 'Can joint formal verification of security and functional invariants reduce functional regressions in LLM-generated Terraform security remediation compared with security-only verification?' Phase 2 should now determine whether the literature supports, challenges, or further refines this question.